

SameSite Lax bypass via method override

Category: CSRF / SameSite Cookie Bypass

Platform: PortSwigger Web Security Academy

Difficulty: Practitioner

Tool: Burp Suite

Objective

Bypass CSRF protection based on the `SameSite=Lax` cookie attribute by abusing HTTP method override functionality.

Vulnerability

The application relies on `SameSite=Lax` cookies to reduce CSRF risk. However, the application supports overriding the HTTP method through a request parameter. This creates a way to transform a cross-site request into the required method while still allowing the browser to include the user's authentication cookie.

Methodology

1. Identified a sensitive endpoint protected primarily by `SameSite=Lax`.
2. Analyzed the application's support for HTTP method overriding.
3. Constructed a cross-site request using the method override functionality.
4. Used the request to cause the application to process the request as the required HTTP method.
5. Confirmed that the authenticated action was executed successfully.

Impact

An attacker may bypass the intended CSRF protection and perform unauthorized actions using the victim's authenticated session.

Remediation

Do not rely on `SameSite=Lax` as the only CSRF defense. Implement robust, session-bound CSRF tokens and ensure that HTTP method handling cannot be abused to bypass security controls.

References

- PortSwigger Web Security Academy – CSRF
- OWASP – Cross-Site Request Forgery Prevention